The Gentlemen Ransomware (Storm-2697): Catena d'attacco, EDR-Killing e idee di detection

Autore: Alessio Lacava - Threat Intel (junior) | Data: 2 ottobre 2026 | Analisi basata su fonti pubbliche

1. Sintesi

The Gentlemen (tracciato da Microsoft come **Storm-2697** e noto anche come *ArmCorp*) è un'operazione Ransomware-as-a-Service (RaaS) a doppia estorsione emersa a metà del 2025 ed esplosa nella prima metà del 2026, posizionandosi rapidamente come una delle minacce più attive a livello globale con centinaia di vittime rivendicate. Il gruppo si distingue nel panorama cyber del 2026 per un modello di business aggressivo, offrendo agli affiliati fino al **90% del riscatto**, attirando così esperti di penetrazione ed ex membri di cartelli storici come Qilin.

Il cifratore, sviluppato in linguaggio Go, colpisce principalmente ambienti **Windows**, estendendo le capacità d'impatto a sistemi **Linux e VMware ESXi**. Gli attacchi si basano sullo sfruttamento sistematico di vulnerabilità su apparati di frontiera, in particolare dispositivi **FortiGate**, o sull'acquisto di credenziali compromesse da brokers.

Perché interessa ai difensori: Il gruppo ha industrializzato l'evasione delle difese fornendo ai propri affiliati un framework proprietario di EDR-killing denominato **GentleKiller**. Il malware incorpora inoltre un modulo di **autopropagazione in stile worm** basato su argomenti PowerShell e credenziali hardcoded, capace di paralizzare rapidamente intere reti aziendali.

2. Catena d'attacco

Fase	Evidenza riportata	Fonte	Conf.
Initial Access	Sfruttamento di server internet-facing vulnerabili (FortiGate CVE-2024-55591) e credenziali di dominio compromesse senza MFA.	Trend Micro, CUHK ITSC, Palo Alto Unit 42	Alta
Discovery	Scansione di rete tramite Advanced IP Scanner e Nmap; script personalizzati per l'enumerazione massiva degli account.	Trend Micro, FortiGuard Labs, Check Point	Alta
Defense Evasion	Distribuzione del framework GentleKiller (almeno 8 varianti BYOVD) combinato con tool terzi (HexKiller, ThrottleBlood via driver ThrottleBlood.sys). Suite Ring-0 per terminare oltre 400 processi di sicurezza.	ESET Research, Cloud Security Alliance	Alta

Persistence / C2	Installazione dell'utility AnyDesk come finto servizio, script PowerShell, proxy SOCKS5 (SystemBC) o tunnel Cloudflare.	Trend Micro, Devel Group, Check Point	Alta
Lateral Movement	Modulo autopropagante (worm-like) che tenta fino a 21 tecniche di esecuzione remota simultanee (PsExec, WMIC, WinRM, SMB/NETLOGON, GPO dirottati).	Microsoft Security Blog, Devel Group	Alta
Exfiltration	Staging via WebDAV o tool interni (OxideHarvest); esfiltrazione cifrata via WinSCP/Rclone verso server controllati prima della cifratura.	Trend Micro, Devel Group, SOCRadar	Alta
Impact	Cifratura basata su Curve25519 e XChaCha20. Eliminazione copie shadow (VSS), rimozione log eventi e rilascio nota README-GENTLEMEN.txt. Estensione .umc16h.	Microsoft Security Blog, Trend Micro	Alta

3. Mappatura MITRE ATT&CK;

Tattica	ID	Tecnica	Origine del mapping
Initial Access	T1190	Exploit Public-Facing Application (FortiGate / VPN)	FortiGuard Labs / SOCRadar
Initial Access	T1078	Valid Accounts (Domain Credentials comprati da IAB)	SOCRadar / Trend Micro
Execution	T1059	Command and Scripting Interpreter	SOCRadar / Microsoft
Persistence	T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	SOCRadar
Persistence	T1053.005	Scheduled Task (UpdateSystem per persistenza)	Devel Group / SOCRadar
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools (GentleKiller BYOVD)	ESET Research / SOCRadar
Lateral Movement	T1021.002	Remote Services: SMB/Windows Admin Shares	Trend Micro / Microsoft
Lateral Movement	T1080	Taint Shared Content (Manipolazione via GPO)	SOCRadar / Trend Micro
Exfiltration	T1567.002	Exfiltration to Cloud Storage (WinSCP verso WebDAV)	Trend Micro
Impact	T1490	Inhibit System Recovery (Cancellazione copie VSS)	Microsoft / SOCRadar

Impact	T1486	Data Encrypted for Impact (Estensioni .umc16h / .7mtzhh)	Microsoft / Trend Micro

4. Indicatori di compromissione (da fonti pubbliche)

Tipo	Valore	Contesto e fonte
File / Driver	ThrottleBlood.sys	Driver legittimo abusato per BYOVD kernel-level.
Software	All.exe	Payload anti-AV usato per disabilitare Windows Defender.
Task Name	UpdateSystem	Attività pianificata malevola creata per la persistenza.
Tool / Utility	OxideHarvest	Framework interno custom usato per la raccolta dati.
Estensione	.umc16h	Estensione applicata ai file cifrati (variante Go di Microsoft).
Estensione	.7mtzhh	Variante di estensione osservata sul campo.
Ransom Note	README-GENTLEMEN.txt	Nota di riscatto lasciata nelle cartelle cifrate.

5. Idee di detection e hunting

• **Abuso di driver vulnerabili (BYOVD):** Monitorare il caricamento di driver insoliti come ThrottleBlood.sys. Tracciare l'evento Sysmon Event ID 6 (Driver Loaded) o l'evento Windows Security 7045.
• **Modifiche alle GPO:** Configurare allarmi SIEM per rilevare modifiche massive e non pianificate ai Group Policy Objects in Active Directory, in particolare variazioni nella cartella SYSVOL.
• **Comportamento Worm / Movimento Laterale:** Rilevare picchi improvvisi di tentativi di connessione remota eseguiti contemporaneamente da un singolo host tramite SMB (porta 445), WinRM o WMIC/PsExec.
• **Utilizzo anomalo di WinSCP / WebDAV:** Monitorare processi come winscp.exe avviati da percorsi temporanei o eseguiti da account di servizio locali.

6. Mitigazioni suggerite dalle fonti

• **Hardening Anti-BYOVD:** Implementare in modo rigido le blocklist di driver vulnerabili fornite da Microsoft (HVCI o WDAC) per impedire il caricamento di file a livello kernel manipolati da GentleKiller.
• **Gestione configurazioni esterne:** Patchare immediatamente i sistemi esposti a Internet, in particolare i firewall FortiGate (CVE-2024-55591).
• **Controlli dell'Identità:** Imporre l'autenticazione a più fattori (MFA) su tutti gli account amministrativi, monitorando i tentativi falliti o l'enumerazione di massa degli account Active Directory.
• **Protezione dei Backup:** Mantenere backup rigorosamente offline, isolati e non modificabili (immutable backup).

7. Regole di detection (didattiche)

YARA Rule:

```
rule Ransomware_TheGentlemen_Go_Educational
{
    meta:
        description = "Educational rule for The Gentlemen ransomware"
        author = "Alessio Lacava"

    strings:
        $note = "README-GENTLEMEN.txt" ascii wide
        $ext1 = ".umc16h" ascii wide
        $framework = "GentleKiller" ascii wide
        $driver = "ThrottleBlood.sys" ascii wide nocase

    condition:
        uint16(0) == 0x5A4D and (1 of ($note, $ext1)) and ($framework or
$driver)
}
```

8. Limiti dell'analisi

• **Dipendenza esclusiva da report di terze parti:** nessuna analisi in sandbox o reverse engineering eseguiti in prima persona.
• **Dinamismo dei RaaS:** le TTP e gli indicatori infrastrutturali possono mutare rapidamente nel corso del 2026.

9. Riferimenti

[1] Microsoft Threat Intelligence, *The Gentlemen ransomware: Dissecting a self-propagating Go encryptor*, 2026.
[2] ESET Research, *Killing me gently: Inside Gentlemen's EDR killer framework*, 2026.
[3] Trend Micro Research, *Unmasking The Gentlemen Ransomware*, 2025/2026.
[4] Cloud Security Alliance (CSA), *GentleKiller: Inside the Gentlemen RaaS EDR-Killer Suite*, 2026.
[5] Recorded Future, *Social Engineering in the Age of Synthetic Media*, 2026.